Part 10 Brief · Terraform blueprint on HIPAA-eligible AWS

mcp-ops-server · 21 Oct 2026 · PR #22 · Status: Cursor Security fixed (2x medium); Codex review pending · validated, never applied

WHAT WAS BUILT (INFRA/AWS/: 1,270 LINES OF HCL, 340 OF TESTS)

- **A private Fargate service:** one task, image pinned by digest from an immutable, scanned ECR repo, uid 10001, read-only root, every capability dropped, no ECS Exec, no public IP. An internal ALB (TLS 1.2+) behind a WAF (known bad inputs, rate limit per IP across tasks). No internet gateway, NAT or Elastic IP: AWS APIs through VPC endpoints, the FHIR server through `fhir_cidrs` only.
- **Storage and keys:** EFS access points for tokens (read-only to the server), audit log and SQLite; the data key in Secrets Manager, set out of band so it never enters state; two rotated KMS keys; logs kept 400+ days.
- **Least privilege in IAM:** the server can read the tokens file but not write it, so it cannot grant itself a token; an on-demand admin task issues and revokes tokens but cannot write the audit log.

HOW CI CHECKS IT (NEW TERRAFORM JOB; NO AWS CREDENTIALS EXIST)

Check	What it proves
fmt, init (lock file), validate	well-formed; provider 6.68.0 pinned by hash for 5 platforms
terraform test: 17 runs	on a mocked provider: hardening, IAM split, network, TLS, encryption; 8 bad inputs refused
tflint + AWS ruleset, checkov	196 checkov checks pass; each of 8 skips has its reason beside the resource
scripts/check_infra.py (+15 pytest)	every type maps to a HIPAA-eligible or no-PHI service; no IGW/NAT/EIP, no 0.0.0.0/0; settings and uid match the server
container job	the image now runs read-only with no capabilities, as the task does

WHY IT WAS DONE THIS WAY

- **Never applied.** Reviewable infrastructure without a PHI endpoint to operate or pay for. **Tests on a mock, not just linters:** checkov knows AWS defaults, not this server's rules (read-only tokens, one writer, the real clock).
- **One task.** The audit log and database take exclusive locks, so deploys stop the old task first. Scaling out needs a shared audit sink; I wrote that down instead of hiding it.

WHAT WENT WRONG OR SURPRISED ME (LOGGED IN FAILURES.MD)

- **The image's default clock is the synthetic demo time.** Deployed as is, it would think it is always 2 Nov 2026, 08:00. The task sets `MCP_OPS_NOW=system`, and a test pins it.
- **checkov caught a real portability bug:** zone *names* differ per account, so subnets now use zone IDs. I dropped an ECR lifecycle rule that could expire the digest a running task names. **22 of 22** deliberately broken safeguards made a test fail.
- **This session could not reach** the Terraform registry, AWS's site or Docker Hub. The provider came from HashiCorp's release server, and the base image from Google's mirror at the same digest. AWS's HIPAA list was checked through search only, so the catalog marks each service official, secondary or (S3) unverified. **Cursor Security found 2 token leaks:** WAF samples skip redaction (sampling now off), and admin `issue` printed tokens into CloudWatch (`issue --sha256` now registers a hash you made).

VERIFY IT YOURSELF

```
cd infra/aws && terraform init -backend=false && terraform test   # 17 passed
tflint --init && tflint; checkov -d . --framework terraform --skip-download
cd ../.. && python scripts/check_infra.py && pytest -q          # 539 passed
```

INTERVIEW TALKING POINT

"Linters pass AWS best practice; they do not know that my server must not be able to write its own tokens file. So the blueprint has plan-time tests against a mocked provider, and I broke each safeguard to see a test fail."

NEXT (YOUR ACTIONS)

1) Add **terraform** to the main ruleset's required checks after merging. 2) Paste the Codex prompt. 3) Check the services in hipaa-services.json against AWS's live list. 4) Say **go** for Part 11.